

What goes wrong, and what stops it

Four failure modes, and the control that actually addresses each one.

🛡️ CONTROL

⚠️ FAILURE

📊 MEASURE

THE FAILURE

⚠️ Prompt injection

Text the system treats as instructions when it was only ever content. The dangerous form arrives in a page, a file or a repo the agent read — nobody typed it.

⚠️ Indirect prompt injection

⚠️ Jailbreak

⚠️ Hallucination

Plausible, confident and wrong, produced identically to correct output — because truth is not a quantity the model computes.

⚠️ AI slop

⚠️ Excessive agency

More permission, autonomy and reach than the task needs — and drift outside the intended scope while every individual action still looks permitted.

⚠️ Rogue agent

⚠️ Exfiltration and tool misuse

Legitimate access and legitimate tools, used exactly as designed, to do something you did not want — which is what makes both hard to spot.

⚠️ Tool misuse

⚠️ Memory poisoning

WHAT ACTUALLY ADDRESSES IT

🛡️ Vet what may configure the agent

A repository supplies configuration, not only code. Decide whether an agent may act on one before it reads it, and check input and output outside the model, where the check cannot be argued with.

🛡️ Guardrails

🛡️ Answer from a source, then check the citation

Retrieve the document and answer from it rather than from what the model remembers — then verify the cited source supports the claim, and that claims needing one have it.

📊 Citation precision and recall

📊 Factuality

🛡️ Say what is allowed, and enforce it below the prompt

Set the limit per action class and put it where it holds: a rule in the system prompt is advice, a rule in the harness is a mechanism.

🛡️ Approval mode

🛡️ Autonomy level

🛡️ Bound the blast radius, and keep a way back

Run commands where a bad step damages a copy, put a person in the path of what cannot be undone, and snapshot as you go so an hour is recoverable.

🛡️ Human in the loop

🛡️ Checkpoint and rollback

HOW YOU FIND THEM

📊 **Red teaming** — Deliberately trying to make it misbehave, rather than checking that it behaves.

📊 **Evaluation** — A repeatable test, so a fix can be shown to have worked.

WHAT SHOULD TRAVEL WITH THE ARTIFACT

🛡️ **Provenance** — Evidence of where a model, dataset or piece of content came from — attached to the thing, not asserted about it.

THE PATTERN IN ALL FOUR

🛡️ **Give it its own identity** — An agent acting as you is indistinguishable from you in every log. Its own credentials are what make the other controls observable.

Every control here sits outside the model. A rule in the system prompt is advice; a rule in the harness is a mechanism; a rule in the sandbox holds even if the other two are talked around.